



Grundlagen der Resilienz

Cyber Security Management · Termin 1

Prof. Dr. Dirk Loomans

About ...

Prof. Dr. Dirk Loomans, Diplom-Physiker

- Studium Physik und Informatik (Bayreuth), Promotion in theoretischer Polymerphysik (Freiburg).
- ehem. Partner Cyber Security and Resilience bei KPMG, CEO Loomans & Matz, CISO Infineon
- Hochschule Mainz, Fachbereich Wirtschaft: Wirtschaftsinformatik, insbesondere Cyber Security und Softwareentwicklung (WiSe 2011/12 – SoSe 2015 und seit SoSe 2025)
- Lehre: Projektmanagement, Cyber-Resilienz, IT-Security, Digital Business
- Forschung: KI und Cyber, Digitale Souveränität
- Fun Fact: Hobbybrauer und Fastnachts-Aficionado



Zugang zum Kurs in OLAT

Kursunterlagen, Skripte und Ankündigungen liegen in OLAT.
Zugangskennwort: CSMWS26ECR

Semesterüberblick

1. **Grundlagen der Resilienz: Safety & Security** ← heute
2. Modelle und Messbarkeit
3. Resilienz-Architekturen
4. Cyber-Bedrohungen und Resilienzstrategien
5. Resilienz als Organisationsfähigkeit
6. Rollen und Verantwortlichkeiten
7. Technische Resilienz I: Backup, DR, Notfalltests
8. Technische Resilienz II: Zero Trust, Microsegmentation, Cloud, Netz
9. Sonderthemen OT und KI · 10. Resilienz der Zukunft · 11. Klausur

Agenda

- Einleitung & Lernziele
- Begriff und Herkunft der Resilienz
- Safety vs. Security
- Physikalisch-systemische Perspektive
- Technische Resilienzprinzipien
- Standards und Regulierung
- Fallstudien & Übung
- Zusammenfassung & Ausblick



Flaschenlager Kupferberg, Mainz



Lernziele

Nach dieser Sitzung können Sie ...

- den Begriff **Resilienz** definieren und von Robustheit, Zuverlässigkeit und Sicherheit abgrenzen,
- den Unterschied zwischen **Safety** und **Security** erläutern,
- technische und organisatorische **Resilienzprinzipien** benennen und anwenden,
- Resilienz in **Cyber-Security-Management, Business Continuity und Incident Response** einordnen.

Warum Resilienz wichtig ist

IT-Systeme sind nie vollkommen sicher.

Angriffe, Ausfälle und Fehlbedienungen sind unvermeidlich.

Entscheidend ist: Wie schnell können wir uns erholen und weiterarbeiten?

Diskussionsfrage: Wie lange darf euer Lieblingsspiel down sein?

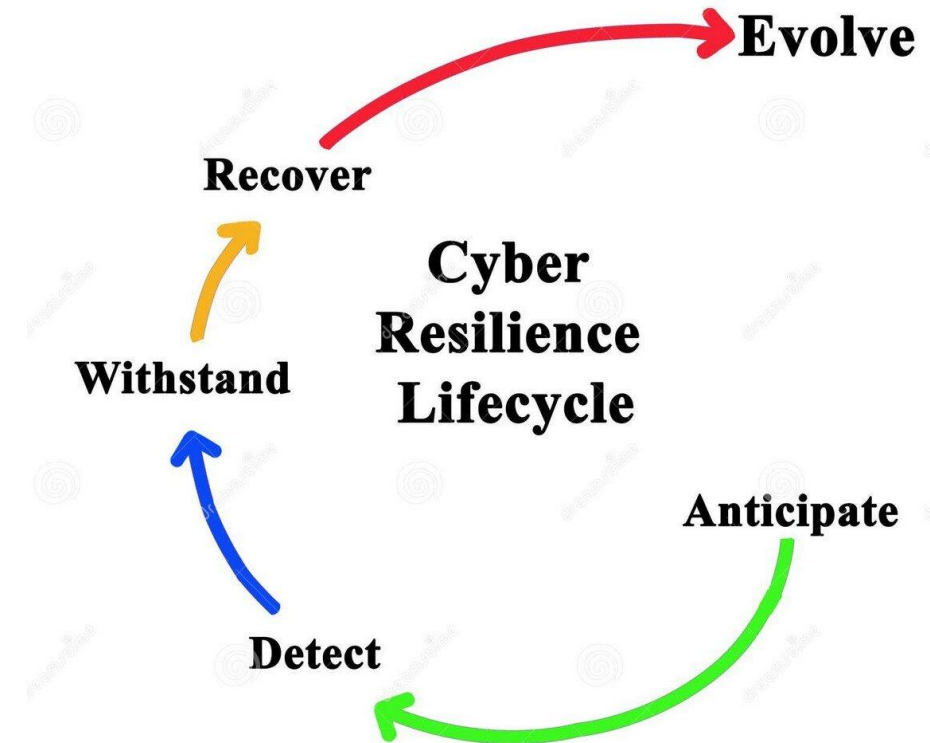
Ausfälle sind normal: 19. Juli 2024

- Ein fehlerhaftes Update einer **Sicherheitssoftware** (CrowdStrike Falcon)
- Rund 8,5 Mio. Windows-Rechner bleiben im Bluescreen hängen – Flughäfen, Kliniken, Banken, Sender
- Kein Angriff – und trotzdem ein massiver Sicherheitsvorfall
- Wiederherstellung oft nur manuell, Rechner für Rechner



Was bedeutet Resilienz?

- Resilienz = Widerstands- und Anpassungsfähigkeit bei Störungen.
- Herkunft: Physik, Psychologie, Systemtheorie – heute technische und organisatorische Systeme.
- In der IT: Systeme bleiben trotz Störungen funktionsfähig oder erholen sich schnell.

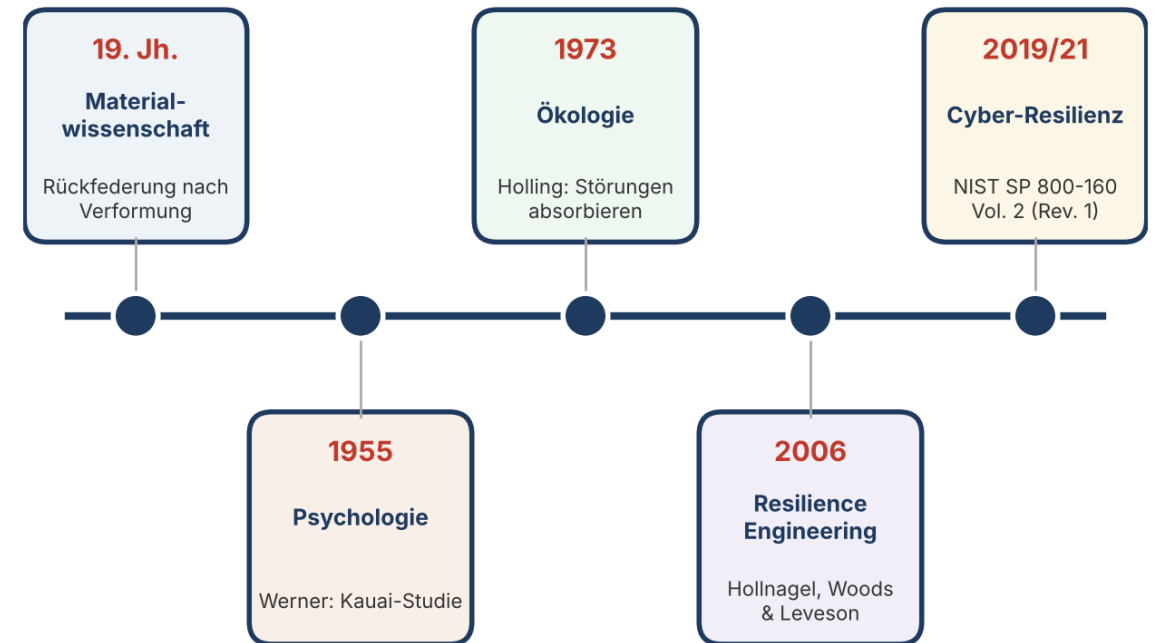


Resilienz ist nicht dasselbe wie ...

Begriff	Leitfrage	Bild
Robustheit	Hält das System der Störung stand, ohne nachzugeben?	Fels
Zuverlässigkeit	Funktioniert es unter Normalbedingungen dauerhaft?	Uhrwerk
Sicherheit	Ist es vor Schäden und Angriffen geschützt?	Tresor
Resilienz	Bleibt es funktionsfähig, erholt es sich – und lernt es?	Bambus im Sturm

Woher kommt der Begriff?

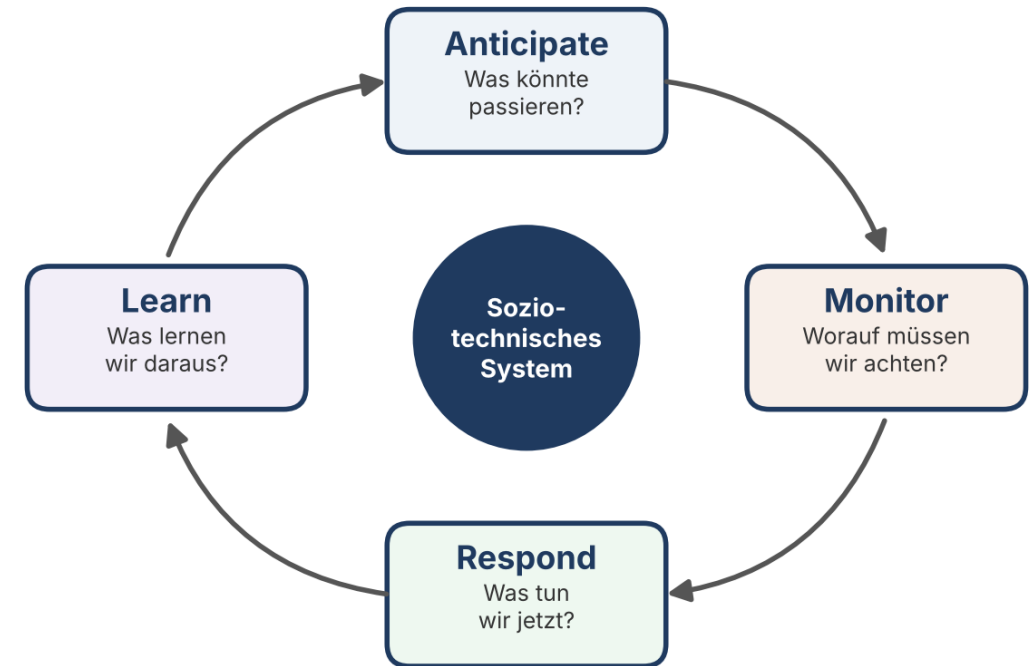
- **Materialwissenschaft** (19. Jh.): Rückfederung nach Verformung
- **Psychologie**: Emmy Werner, Kauai-Längsschnittstudie (ab 1955)
- **Ökologie**: C. S. Holling (1973) – Ökosysteme absorbieren Störungen
- **Resilience Engineering**: Hollnagel, Woods & Leveson (2006)
- **Cyber**: NIST SP 800-160 Vol. 2 (2019, Rev. 1 2021)



Resilience Engineering: vier Fähigkeiten

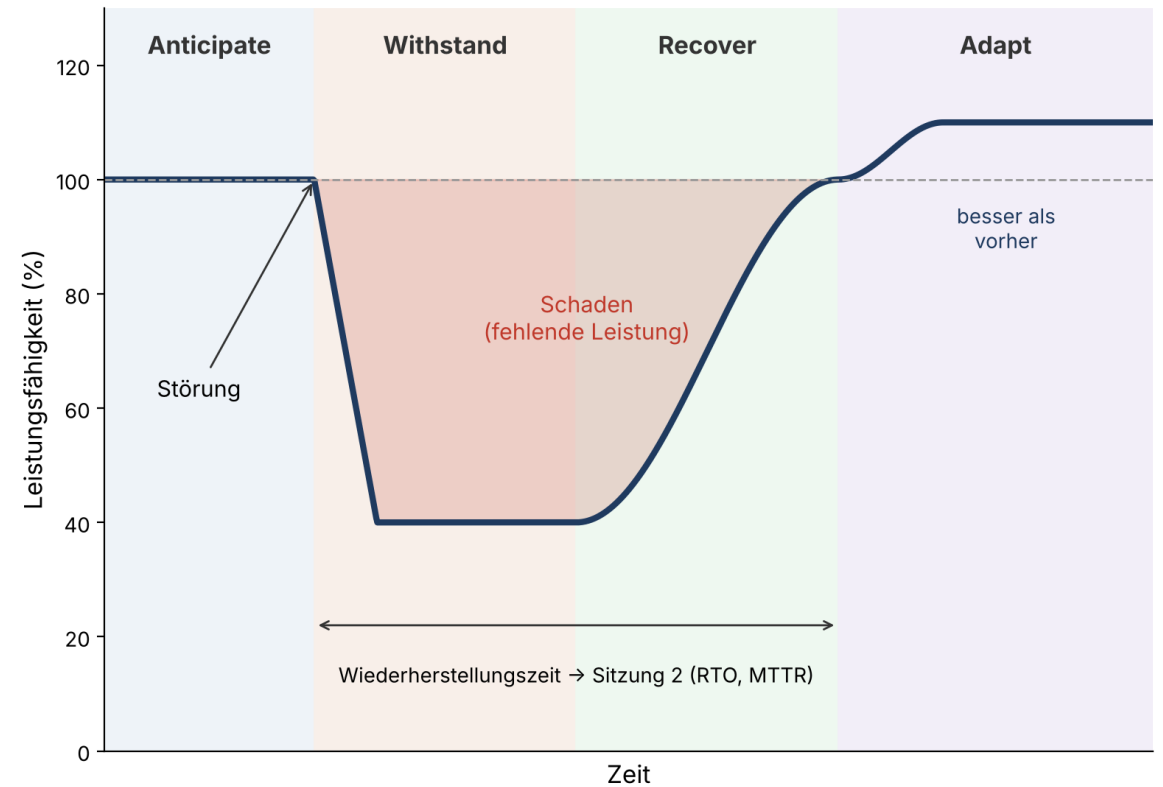
- **Anticipate** – Was könnte passieren?
- **Monitor** – Worauf müssen wir achten?
- **Respond** – Was tun wir jetzt?
- **Learn** – Was lernen wir daraus?

Resilienz ist etwas, das ein System **tut** – nicht etwas, das es **hat**.



Die Resilienzkurve

- Störung → Leistungsabfall → degradierter Betrieb → Wiederherstellung → Anpassung
- NIST-Ziele: **Anticipate, Withstand, Recover, Adapt**
- Die Fläche „fehlender Leistung“ ist der Schaden
- Resilienz heißt: Abfall flacher, Erholung schneller, danach besser



Safety vs. Security – der Unterschied

Safety: Schutz vor unbeabsichtigten Fehlern und Unfällen – Hardwaredefekt, Stromausfall, Brand.

Security: Schutz vor absichtlichen Angriffen – Ransomware, Social Engineering, Hacking.

Beide beeinflussen die Resilienz eines Systems.



Wo Safety und Security sich treffen

- **Security** → **Safety**: Stuxnet (2010) – Schadcode zerstört Uranzentrifugen physisch
- **Security** → **Versorgung**: Colonial Pipeline (2021) – Ransomware in der IT, Pipeline (OT) vorsorglich abgeschaltet, Treibstoffengpässe an der US-Ostküste
- **Safety** → **Security**: Notbetrieb und Fail-open öffnen Angriffsflächen
- Frage: Wo kippt es bei Smart Home, Auto, Cloud-Gaming?



Resilienz verbindet beides

Ziel: nicht Unverwundbarkeit, sondern Reaktions- und Wiederherstellungsfähigkeit.

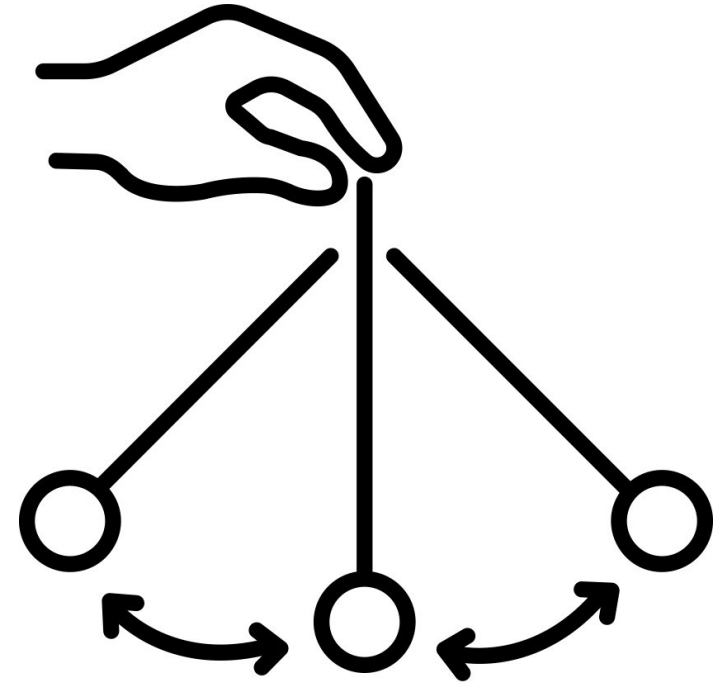
Safety + Security + Adaptivität = Resilienz

Fokus: robust designen, Störungen erkennen, reagieren, wiederherstellen.



Physikalische Perspektive (Analogie)

- Pendel / Schwingkreis: Störung → Auslenkung → Rückkehr zur Balance.
- Elastizität vs. Fragilität: Gummi vs. Glas.
- Übertragung auf IT-Systeme und Organisationen: Monitoring, Alerting und Autoscaling wirken wie Regelkreise.



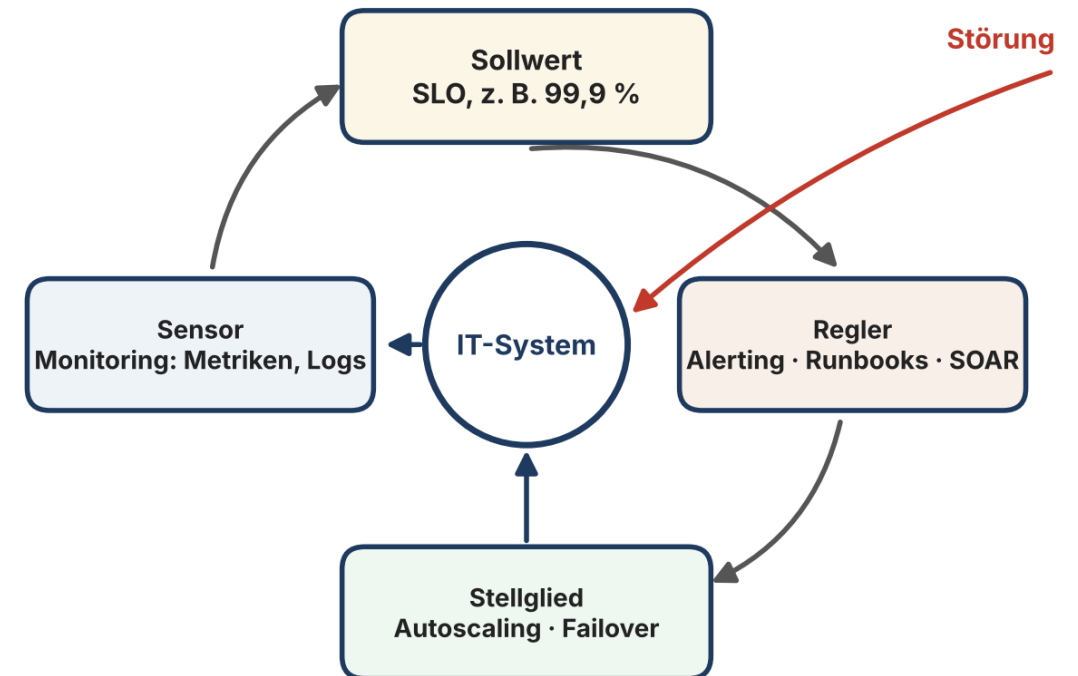
Pendulum

VectorStock

VectorStock.com/50999399

Der Regelkreis im IT-Betrieb

Regelungstechnik	IT-Betrieb
Sollwert	Service Level Objective (SLO)
Sensor	Monitoring: Metriken, Logs
Regler	Alerting, Runbooks, SOAR
Stellglied	Autoscaling, Failover, Isolation



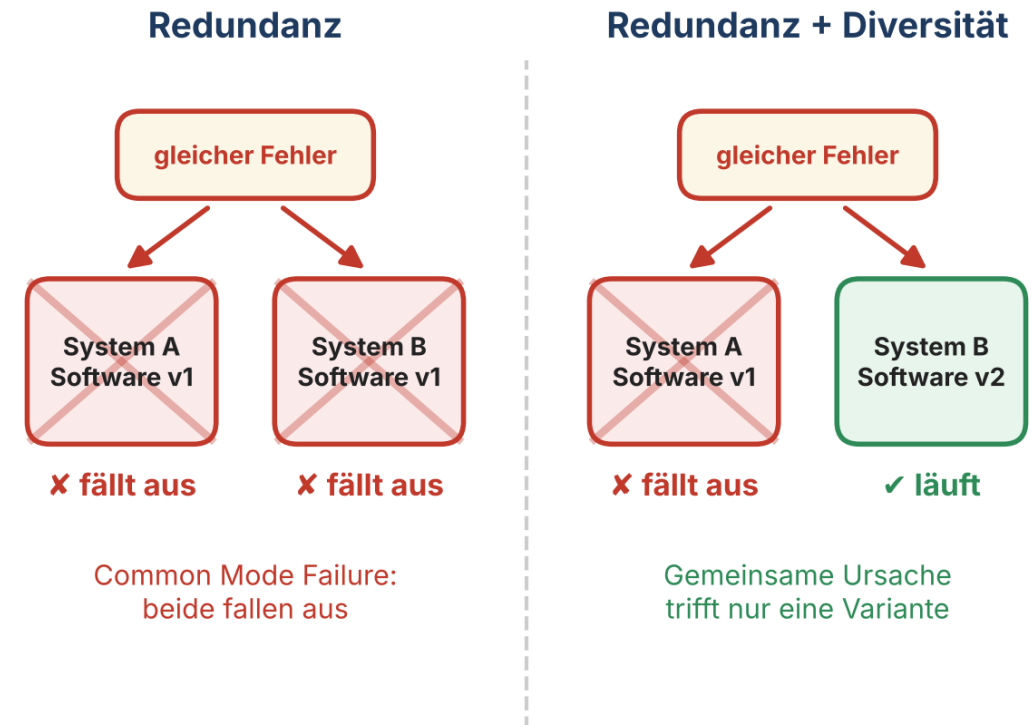
Technische Resilienzprinzipien

- **Redundanz** – mehrere Wege und Komponenten
- **Diversität** – heterogene Komponenten reduzieren Kaskadenfehler
- **Wiederherstellbarkeit** – Backups, DR-Prozesse, Automatisierung
- **Adaptivität** – Skalierung, Umschalten, Lernen



Redundanz ohne Diversität: Ariane 5

- Flug 501 (1996): zwei redundante Trägheitsnavigationssysteme
- Identische Software → identischer Fehler (Zahlenüberlauf), beide fallen kurz nacheinander aus
- Rakete zerstört sich nach ca. 37 Sekunden
- Redundanz schützt vor **zufälligen** Fehlern, nicht vor **gemeinsamen Ursachen** (Common Mode Failure)



Wiederherstellbarkeit: Das Kupferberg-Problem

- 1960: Kupferberg stellt auf Edelstahltanks um – das Flaschenlager bleibt als **Fallback**
 - Heute weiß niemand mehr, welche Flaschen noch voll sind
 - Bewegen? Flaschen könnten platzen – Kettenreaktion
- Ein Backup, das nie getestet wurde, ist eine Hoffnung.**



Glück ist keine Strategie: Maersk & NotPetya

- Juni 2017: NotPetya – Wiper, getarnt als Ransomware, verbreitet über ukrainische Buchhaltungssoftware
- Maersk: Tausende Server, zehntausende PCs unbrauchbar, alle Domain Controller verschlüsselt – bis auf einen
- Der letzte stand in **Ghana** und war wegen eines Stromausfalls offline
- Wiederaufbau in rund zehn Tagen, Schaden mehrere hundert Mio. USD



Adaptivität: Chaos Engineering

- Netflix „Chaos Monkey“ (ab 2011): fährt in Produktion zufällig Instanzen herunter
- Vorgehen: Hypothese → Experiment → Beobachten → Lernen
- Blast Radius klein halten, Abbruchkriterien festlegen
- **Game Days**: geplante Ausfallübungen mit dem ganzen Team



Warum Prävention nicht reicht

- Zero-Days, Lieferketten, menschliche Fehler
 - 100 % Prävention gibt es nicht.
 - **Resilienz ist die letzte Verteidigungslinie.**
- „Sicherheit schützt – Resilienz überlebt.“

PREVENT PREPARE RESPOND RECOVER



Resilienz steht im Gesetz

Standards & Frameworks

- NIST SP 800-160 Vol. 2 Rev. 1 · ISO/IEC 27031:2025 · BSI-Standard 200-4 · ENISA-Leitfäden

EU-Regulierung

- NIS2 – Pflichten und Haftung der Leitung
- DORA – *Digital Operational Resilience Act* (seit Januar 2025)
- CER-Richtlinie – *Critical Entities Resilience*
- Cyber **Resilience** Act – Produkte mit digitalen Elementen



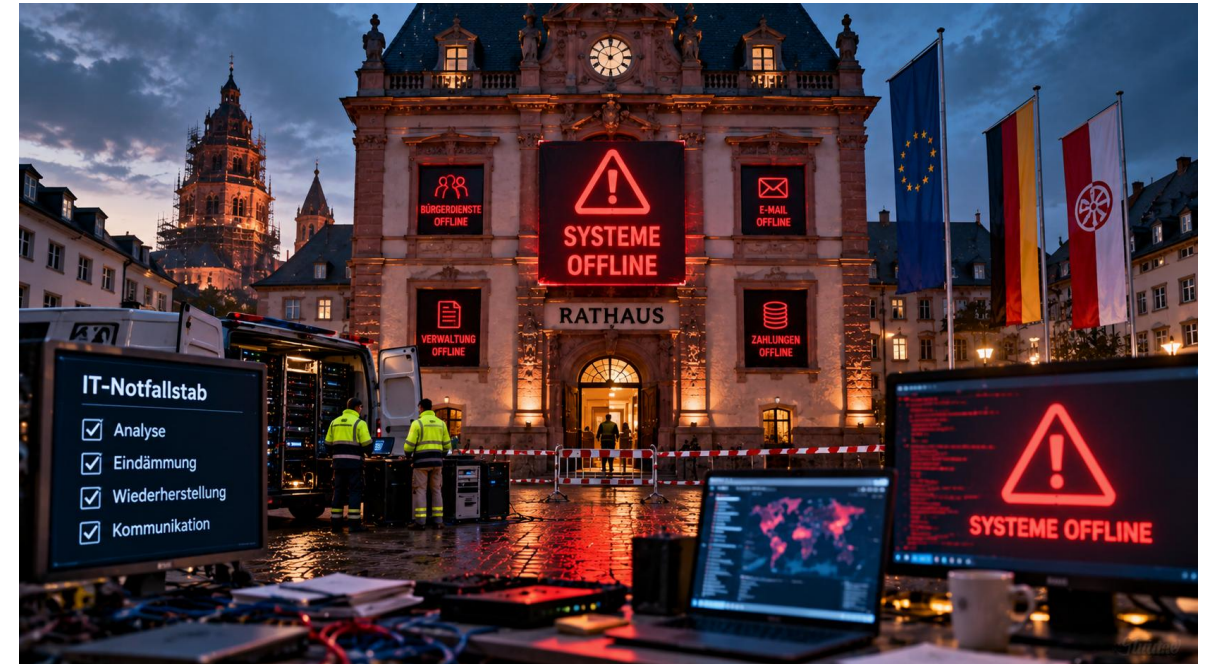
Relevanz für Cyber Security Management

- Resilienz ist ein Management- und Architekturthema.
- Standards liefern das Vorgehen, Regulierung macht Resilienz zur Leitungsaufgabe.
- Verbindung zu Incident Response, BCM und IT Service Continuity Management.

Fallstudie: Ransomware in der Verwaltung

- **Anhalt-Bitterfeld (2021):** erster Cyber-Katastrophenfall Deutschlands, Bürgerdienste monatelang gestört
- **Südwestfalen-IT (2023):** ein kommunaler IT-Dienstleister, rund 70 Kommunen betroffen – Konzentrationsrisiko
- Entscheidend: offline verifizierte Backups, priorisierter Wiederanlauf nach BCM-Plan, Kommunikation

Frage: Welche Maßnahmen beschleunigen die Wiederherstellung?



Fallstudie: DDoS auf einen Online-Service

- **Mirai / Dyn (Oktober 2016):** Botnetz aus IoT-Geräten (Kameras, Router) legt den DNS-Anbieter Dyn lahm – große Plattformen nicht erreichbar
- Maßnahmen: Anycast, CDN, WAF, elastische Kapazität
- DNS bei mehreren Anbietern = Diversität
- Transparente Statuskommunikation



Übung: Safety oder Security?

Gruppenaufgabe mit Szenarien: Cloud-Gaming, Krankenhaus-IT, Smart Home, Auto, Banking-App.

1. Risiken identifizieren
 2. Safety vs. Security zuordnen
 3. Resilienzmaßnahmen vorschlagen
- 5-Minuten-Kurzpräsentation pro Gruppe.

Kernpunkte

- „**Sicherheit schützt – Resilienz überlebt.**“ Prävention ist notwendig, aber nicht hinreichend.
- Safety und Security adressieren unterschiedliche Ursachen – Resilienz integriert beide.
- **Design for Failure:** Redundanz, Diversität, Wiederherstellbarkeit, Adaptivität.
- Resilienz braucht Technik, Prozesse und Menschen – und lebt von Übung und Lernen.

Ausblick & Hausaufgabe

Nächste Sitzung: Modelle und Messbarkeit der Resilienz (RTO/RPO, MTTR, SLOs).

Hausaufgabe: Ein Beispiel recherchieren, das sich nach einer Störung besonders schnell erholte.

[Kapitel zum Termin](#) · [Glossar](#) · [Quellen](#)